

STRICTLY CONFIDENTIAL // INTERNAL ONLY

Enterprise Cloud Security Architecture & Identity Access Management (IAM) Guidelines

Technical Standard for Multi-Region AWS Implementations

Document Reference: SEC-2026-X901

Classification Level: Tier-1 Confidential

Effective Date: March 15, 2026

Owner: Global Infrastructure Security Group

Approved By: Chief Information Security Officer (CISO)

1. Architectural Scope & Objectives

This technical standard defines the mandatory security controls, identity boundary definitions, and network perimeter isolation strategies required for all multi-region web applications operating within TechCorp Global cloud infrastructure. Non-compliance with these rules automatically triggers isolated remediation workflows within the deployment orchestrator, revoking active staging routing protocols.

Critical System Dependency

All parameters defined in Section 2.2 explicitly override generic cloud vendor default network routing layouts. Failure to align routing maps with policy `SEC-RULE-404` results in standard compliance audit triggers.

2. Identity and Access Management (IAM)

2.1 Principal of Least Privilege (PoLP)

No infrastructure runtime components may be deployed with wildcard asterisk permissions (e.g., `"Action": "*"`). All execution runtimes, including managed container pods and serverless compute functions, must assume dedicated IAM roles with crisp, explicitly bounded authorization boundaries. Session durations for cross-account execution assumptions are strictly capped at 3,600 seconds (1 hour).

2.2 Core Infrastructure Authentication Matrix

The following deployment paradigms dictate access criteria across global cloud endpoints:

Environment ID	Authentication Mechanism	IP Range Restriction	MFA Requirement
ENV-DEV-01	Federated IdP SSO (SAML 2.0)	<code>10.240.0.0/16</code>	Optional (Soft-Token)
ENV-STG-02	Federated IdP SSO + Active Directory	<code>10.180.0.0/16</code>	Mandatory (Biometric)
ENV-PROD-99	Hardware Token Assumed IAM Role	<code>192.168.42.0/24</code> Only	Mandatory (Physical Key)

3. Network Security & Cryptographic Protocols

3.1 Data-in-Transit Encryption (TLS 1.3)

All ingress requests passing through external load balancing nodes must exclusively leverage Transport Layer Security (TLS) version 1.3. Legacy protocol versions (including TLS 1.0, 1.1, and standard 1.2) must be

aggressively rejected at the edge gateway. The only sanctioned cryptographic cipher suite allowed for real-time traffic processing within the production profile is `TLS_AES_256_GCM_SHA384`.

3.2 Data-at-Rest Encryption Keys (KMS)

All persistent blocks of data, including object stores, relationally indexed databases, and ephemeral worker node volume drives, must utilize customer-managed keys (CMKs) stored inside the centralized Key Management Service. These cryptographic keys must undergo fully automated 90-day rotational lifecycles orchestrated by security operations routines.

4. Incident Response & Threat Identification

When an unauthorized data exfiltration event or unusual access vector signature is discovered by algorithmic logging layers, the system enters an automated lockup status code sequence. The security operational protocol dictates the following sequential response tier pipeline:

1. **Isolate:** The compromised asset or virtual node is detached from active target groups and mapped directly to an isolated forensic virtual private cloud (VPC) subnet (`VPC-ID: vpc-0ffff8888baaa333`).
2. **Snapshot:** Full cryptographic state copies of all attached memory layers and file volumes are pulled and stored safely within an immutable audit trail repository.
3. **Revoke:** All active IAM access keys and tokens assigned to the target component are immediately invalidated using systemic API calls.

5. Compliance Code Snippet: Guardrail Configuration

The configuration blueprint below represents a structured JSON cloud template fragment illustrating the strict permission blocks evaluated by automated system compliance scanners during deployment pipelines.

```
{
  "Version": "2026-03-15",
  "Statement": [
    {
      "Sid": "StrictDenyUnencryptedDataIngress",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::techcorp-global-vault/*",
      "Condition": {
        "Bool": {
          "aws:SecureTransport": "false"
        }
      }
    }
  ]
}
```

}
]
}